

Reporte Ejecutivo de Gestión de Riesgos

Resumen Ejecutivo

Tras la auditoría externa reciente, que identificó debilidades relevantes en la gestión de riesgos de la institución, se implementó SimpleRisk como herramienta central para registrar, evaluar y dar seguimiento formal a los riesgos de seguridad de la información. Se revelaron 7 riesgos específicos del entorno clínico, vinculados principalmente al Sistema de Historias Clínicas Electrónicas (HCE), el sistema de facturación con obras sociales y la infraestructura tecnológica que sostiene la atención diaria de pacientes

De los 7 riesgos relevados, 3 fueron clasificados en nivel **Alto** y requieren tratamiento prioritario a corto plazo. Para estos casos ya se definieron planes de acción concretos con responsables, plazos y un presupuesto estimado. Los 4 riesgos restante se ubican en nivel **Medio** y serán abordados en una segunda etapa del programa de gestión de riesgos

Top 5 Riesgos por Nivel

Riesgo	Categoría	Valor	Nivel
Ransomware sobre servidor de Historias Clínicas Electrónicas (HCE)	Vulnerabilidad técnica	6.4	Alto
Phishing dirigido al personal administrativo	Gestión de accesos	4.8	Alto
Exposición de historias clínicas por base de datos mal configurada	Datos sensibles	4.0	Alto
Cuentas de exempleados no dadas de baja	Gestión de accesos	3.6	Medio
Corte de energía sin respaldo (UPS/generador)	Resiliencia del entorno	3.6	Medio

Estado de los Planes de Acción

Plan	Riesgo asociado	Responsable	Presupuesto	Estado
Backups aislados y EDR	Ransomware/HCE	Responsable de seguridad	\$700.000-800.000	Planificado
Capacitación anti-phishing + MFA	Phishing administrativo	Analista de riesgos	\$100.000-200.000	Planificado
Auditoría y hardening de BD	Exposición de historias clínicas	Responsable de seguridad	\$200.000-300.000	Planificado

Recomendaciones Prioritarias

1. **Implementar autenticación multifactor (MFA)** en todos los sistemas que acceden a datos de pacientes y facturación, priorizando el sistema de HCE y facturación con obras sociales
2. **Formalizar un proceso de baja de usuarios** vinculado directamente con Recursos Humanos, de forma que ningún acceso quede activo tras la desvinculación de un empleado
3. **Verificar y aislar los backups** del sistema de HCE, con pruebas periódicas de restauración, dado que actualmente no se cuenta con copias verificadas ni aisladas de la red principal
4. **Cifrar en reposo la base de datos de pacientes** y aplicar el principio de mínimo privilegio en los accesos, en cumplimiento de la normativa de protección de datos personales aplicable a información de salud
5. **Incorporar cláusulas de seguridad en los contratos con proveedores externos** (en particular con obras sociales), incluyendo auditorías periódicas de su postura de seguridad